Beyond QASecClaw: Agent Scaling, Verifier Feedback, and Evidence Reliability in Software Assurance

S M Abdulla Al Mamun[1], Akif Islam[2], Mohd. Ruhul Ameen[3]
[1]Department of Computer Science, The University of Manchester, United Kingdom
[2]Department of Computer Science and Engineering, University of Rajshahi, Bangladesh
[3]Department of Computer Science and Engineering, Varendra University, Bangladesh
[1]abdulla5akash@gmail.com, [2]iamakifislam@gmail.com, [3]ruhul@vu.ac.bd

arXiv:2610.36947v1 [cs.SE] 27 Oct 2026

***Abstract*—Can additional specialist language-model contexts improve software assurance when deterministic tool evidence is already available? We study this question through five experiments spanning authored Java warning controls, OWASP Benchmark assessment, Defects4J test generation, SV-COMP assertion verdicts, and deliberately misleading evidence packages. The evaluated systems use Qwen2.5-Coder-7B-Instruct, with a 1.5B sensitivity analysis, and complete 13,638 model requests. On eight related development warnings, increasing the context count from 1 to 50 increases token use 49-fold without improving unsafe clearance. On 160 OWASP cases, model configurations trade clearance against unresolved outcomes; the ten-context arm assesses only 96 cases. On 32 SV-COMP tasks, raw verifier feedback raises mean correct model verdicts from 12.7 to 22.0, but also raises incorrect verdicts from one to seven; a JBMC-plus-JVM validation baseline returns 26 correct verdicts and six unresolved outcomes. On two sets of 120 evidence packages, models reject 70–100% of applicable counterexamples, while construction-specific scope checks classify every package correctly. No target defect is discovered in three Defects4J bugs, one unsupported by the test adapter. These descriptive results support deterministic evidence admission for the tested settings, while exposing limits of verdict aggregation, feedback interpretation, and the available evaluation coverage.**

***Index Terms*—software quality assurance, LLM agents, multi-agent systems, static analysis, bounded model checking, empirical study**

I. Introduction

LLM agents now triage static-analysis warnings [1]–[3], construct verification harnesses [4], translate code into verifiable specifications [5] and reconcile per-function contracts [6]. Many of these systems divide the work among specialist roles, and general results suggest that sampling and voting over more agents can raise accuracy [7]. In assurance, however, the costly error is not a missed answer but a *false clearance*: a real defect dismissed as benign. More voices may add confidence without adding evidence, and recent scaling studies report diminishing or negative returns once coordination overhead and correlated errors are counted [8], [9].

Building on the warning-assessment question raised by QASecClaw, we examine additional dimensions: context scaling, verifier feedback and evidence applicability. The title refers to this broader evaluation scope; we do not reproduce or claim to outperform QASecClaw. We ask: *under fixed evidence, when do LLM agent contexts add assurance value over deterministic checks that already exist?* We study four research questions:

- **RQ1** Does increasing the number of specialist contexts reduce unsafe clearance without inflating abstention or cost?
- **RQ2** Does formal-verifier feedback make model verdicts more reliable than the verifier alone?
- **RQ3** Can models recognise formal evidence that does not apply to the program and property under assessment?
- **RQ4** Can models discover real defects without a supplied warning?

Our contributions are: (i) an executable five-experiment study that separates warning clearance, assertion verdicts, evidence applicability and defect discovery; (ii) a descriptive comparison of 13,638 completed model requests with deterministic controls, including abstention, cost and incomplete coverage; and (iii) a controlled challenge exposing *applicability confusion*, where a model rejects applicable defect evidence because the program is unsafe. The contribution is an empirical diagnosis of these configurations, not a new general verifier or a test of every multi-agent architecture. Request manifests and assessment outputs were frozen before their corresponding scoring stages; unsuccessful attempts remain documented. The study is exploratory, not preregistered.

II. Related Work

Agents for assurance. Table I places this study among the closest systems. QASecClaw filters Semgrep warnings with an LLM agent and reports an 88.6% reduction in false positives on OWASP Benchmark at a 3.1% recall cost [1]. Evident keeps the final disposition with Frama-C/Eva and uses LLMs only to build harnesses; its LLM-as-judge baselines missed confirmed bugs with every model tested [4]. MAGS and VERDICT obtain guarantees through Dafny translation and contract reconciliation [5], [6], and TraceFix verifies the coordination protocol itself [10].

Warning adjudication. Klieber et al. report high recall and specificity using repeated consistency checks and reasoning evaluation [3]. Their stronger reasoning models and different

TABLE I
CLOSEST SYSTEMS AND THE BOUNDARY THEY INVESTIGATE. PRIOR RESULTS ARE CONTEXTUAL COMPARISONS, NOT REPRODUCED BASELINES.

Work	Principal mechanism	Relation to this study
QASecClaw [1]	LLM filtering of SAST reports	Warning disposition
Evident [4]	Validated harness; analyser decides	Deterministic admission
MAGS [5]	Dafny translation and repair	Specification scope
VERDICT [6]	Assumed contracts and reconciliation	Modular obligations
Kim et al. [8]	Controlled agent architectures	Scaling and task fit
This study	Fixed-evidence verdict aggregation	Clearance, abstention and applicability

protocols make model capacity and adjudication policy relevant alternative explanations for our results. Prior studies identify leakage in false-alarm classification [11] and weak generalization on realistic vulnerability data [12]. We therefore report benchmark scope and do not interpret repeated requests as independent evidence.

LLMs with verifiers. Lemur lets LLMs propose invariants that automated reasoners check [13]; SpecGen generates verifiable specifications for SV-COMP Java programs [14]; and local open-weight models paired with ESBMC solve far more tasks than symbolic methods alone [15]. These systems generate artifacts for checking. Our E3 instead asks a model to interpret an unchanged program and raw JBMC feedback [16]; no artifact-generation benefit is evaluated.

III. STUDY DESIGN

A. Assessment pipeline and decision semantics

Fig. 1 shows the experimental interfaces. Each specialist is a fresh, single-turn context with a role instruction; contexts share a base model and task evidence but do not exchange messages, invoke tools interactively or repair the program. Thus, k counts prompted assessments, not autonomous tool-using agents. The single-context arm uses a general assurance analyst. The five-context arm assigns requirement extraction, assumption identification, data-flow analysis, counterexample interpretation and vacuity critique. Larger teams extend a fixed 50-role catalogue. A strict majority of k returns RETAINED or CLEARED; otherwise the outcome is UNRESOLVED. Missing or invalid answers contribute unresolved votes.

The implemented E1/E4 gate is a restricted postprocessor. Let S indicate matching code and property hashes, and E indicate JBMC success with the declared domain $x \in \{0, \ldots, 15\}$ and unwinding assertions enabled. It preserves a proposed clearance only when $S \wedge E$ holds. Otherwise a matching counterexample changes the clearance to retained; absent such evidence it becomes unresolved. Retentions and abstentions are unchanged. Gate-on and gate-off arms reuse identical model outputs. The controls were checked exhaustively on the JVM before assessment; the gate trusts that preparation and the backend

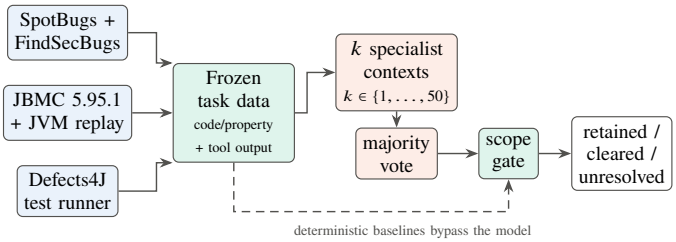

Fig. 1. Overview of the experimental interfaces. Each experiment uses the relevant tool adapter; the tools are not fused into a single end-to-end system. Deterministic baselines bypass the model. E5 outputs accept/reject/unresolved instead of warning dispositions.

parser. It does not prove harness equivalence or implement the proposed general dependency-graph reconciliation.

E5 uses a different gate for evidence *acceptance*. It checks revision/property hashes, full input-domain coverage, required obligations, exact canonical harness text and whether callee assumptions are marked established. A proposed acceptance with any mismatch becomes rejection. This is a construction-specific validator, not a general proof checker; hashes establish identity, not semantic validity.

B. Metrics

For labelled defect cases D, benign cases B, cleared cases C, and unresolved cases U, we report

$$\mathrm{UC} = \frac{|D \cap C|}{|D|}, \quad \mathrm{BC} = \frac{|B \cap C|}{|B|}, \quad \mathrm{UR} = \frac{|U|}{|D| + |B|}. \tag{1}$$

Unsafe clearance (UC) should decrease while benign clearance (BC) increases; unresolved share (UR) exposes abstention. Review workload is the fraction retained or unresolved, not measured reviewer time. Retain-all trivially achieves zero UC but clears no benign cases. We report all three outcomes rather than collapsing them into accuracy. E3 separately scores correct/incorrect/unresolved verdicts; E5 separates corrupted-package acceptance from clean-package rejection; E2 requires a targeted buggy/fixed test differential.

Seeds, variants and packages are repeated or clustered observations. We report counts and seed ranges without significance tests or case-independent confidence intervals. In the ten-context OWASP arm, 64 unassessed cases remain unresolved in the 160-case denominator; we identify these separately from model abstentions. No equal-coverage scaling effect is inferred from that arm.

C. Data, splits and experiments

Table II summarises the experiments. Juliet Java 1.3 contains 28,881 cases in 112 CWE categories [17]. We grouped files into 928 family components, merged duplicate complete contexts, and assigned components to development, validation and evaluation (5,754 / 2,898 / 20,229 cases) with no shared testcase source or duplicate complete context across splits. All CWE476 families were reserved for development. This is a dataset audit: no held-out Juliet model result is reported here. The model controls are eight scanner-flagged programs from one authored

TABLE II
EXPERIMENTS, DATA AND SCALE. REQ. = MODEL REQUESTS.

Exp.	Data (stage)	Req.	Compared arms
E1	8 authored NPE controls (dev)	144	1 vs 5 ctx; ±gate
E4	same controls, 7B + 1.5B (dev)	4,608	1/5/10/25/50; adaptive
E1/E4	160 OWASP cases (held-out)	3,840	$k \in \{1, 5, 10\}$
E2	Defects4J Cli-1/2/3 (dev)	54	1 vs 5 ctx; contract tests
E3	32 SV-COMP tasks (frozen)	192	±feedback; validated backend
E5	20 progs × 6 pkgs (dev)	3,600	±feedback, ±gate
E5	20 progs, new templates (held-out)	1,200	as above

semantic template, obtained after two earlier constructions yielded no warnings; they are not Juliet testcases. OWASP Benchmark 1.2 (2,740 cases, 1,415 real vulnerabilities) [18] was scanned with SpotBugs 4.8.6 and FindSecBugs 1.14.0 [19], [20]; CWE-matched reports covered 1,375 of 1,415 real cases. For held-out assessment we drew a seeded stratified sample of 160 cases: 60 real and 40 benign cases with a matching report, and 40 real and 20 benign cases without one. E2 used three Defects4J Cli bugs [21], each reproduced as a buggy/fixed pair before assessment. E3 used a pinned SV-COMP Java archive [22]: of 1,033 manifests, a structural rule fixed before reading verdicts admitted 111 single-file assertion tasks. It requires a default-package `Main` entry, unused command-line arguments, an assertion property and no explicit imports, threading, native methods or unsupported input APIs; Juliet-derived tasks are excluded. The model comparison takes the first 32 eligible task hashes. These tasks overlap backend calibration, so "frozen describes the request selection, not an independent backend test set. E5 used 20 null-dereference programs from five templates; each has one *clean* package (a JVM-replayed JBMC counterexample) and five *corrupted* packages whose scoped JBMC success is misleading: restricted precondition, suppressing harness, missing obligation, stale revision and unjustified callee assumption. A second set from five disjoint templates served as held-out replication.

D. Models and execution

All inference used Qwen2.5-Coder-7B-Instruct (revision `c03e6d3582`) and, for E4 sensitivity, Qwen2.5-Coder-1.5B-Instruct (`2e1fd397ee`) [23]. The full revision hashes are archived. Sampling used temperature 0.2, top-p 0.95, bfloat16 weights and Transformers 4.51.3. Seeds were 17/43/79 for development and E3, 17/43 for OWASP, and 29 for the second E5 template set. Requests used fresh contexts; batch order and derived batch seeds are recorded, so a seed alone does not ensure cross-hardware reproduction.

For E1/E4 and OWASP, each of k contexts receives at most $\min(8192, \lfloor 65536/k \rfloor)$ input tokens and $\min(512, \lfloor 8192/k \rfloor)$ output tokens. These are shared upper bounds, not equal actual budgets; the one-context arm has much less aggregate capacity. E3 uses 8,192/512 input/output tokens, E5 8,192/256 per context, and E2 32,768/1,536. E2's five-context arm therefore also has a larger budget. We study the observed cost–outcome trade-off, not a budget-matched causal effect of architecture.

TABLE III
E1 DEVELOPMENT CONTROLS, QWEN2.5-CODER-7B, THREE SEEDS (4 DEFECTS AND 4 BENIGN WARNINGS PER SEED).

Method	Unsafe clearance /12	Benign clearance /12	Unresolved /24
Scanner retain-all	0	0	0
Verifier only (no model)	0	12	0
1 context	11	12	1
5 specialist contexts	11	12	1
1 context + scope gate	0	12	1
5 contexts + scope gate	0	12	1

Development ran on university GPUs; the later 5,232 OWASP/E3/E5 requests ran on a Colab A100 in checkpointed batches of 32. Scoring checked frozen request hashes. The 13,638 count is completed final requests, excluding failed attempts and without double-counting gate ablations. E2 additionally records 54 input-cap rejections and 48 out-of-memory failures; the rescue retries failed IDs only. Other failed provisioning attempts are archived separately. A trusted generator renders E2 tests from a restricted declarative schema; arbitrary model-generated Java is not executed.

IV. RESULTS

A. RQ1: Do more contexts reduce unsafe clearance?

Development controls. The eight E1 controls comprise four benign and four defective null-pointer warnings, each with matching JBMC evidence. Table III shows that the ungated model cleared nearly every defect despite being shown the counterexample; inspection confirmed incorrect judgments, not missing context. Five specialist contexts were no better than one. The scope gate removed every unsafe clearance and kept every benign clearance, but the verifier-only baseline already decided all eight correctly.

Scaling. Fig. 2 plots unsafe clearance against token cost for every E4 configuration. From k=1 to k=50 the 7B model's tokens grew from 25,938 to 1,277,612 (49×) while it still cleared 4/4 defects in most seeds; the rare drops came from abstentions, not correct retentions. The 1.5B model cleared every defect in every configuration. The adaptive router activated five roles for every warning because all eight sources matched its trigger, so these data do not test task-dependent routing.

Held-out OWASP. Table IV gives the joint view on 160 held-out cases. Each context saw the source (capped at 12,000 characters), the target CWE and the scanner reports; no verifier evidence exists for this pool, so no gate applies. The clear-without-signal baseline, which clears every case without a CWE-matched report, sits at 40% unsafe and 33% benign clearance. A single context reached 33–36% unsafe and 30–37% benign clearance, with 45–46% unresolved. Five contexts raised unsafe clearance to 39–41%, with 51–53% unresolved. For ten contexts, 111/113 unresolved outcomes include 64 deliberately unassessed cases per seed; among the 96 assessed cases, 47/49 were unresolved. Its lower full-denominator unsafe clearance is therefore not evidence of a scaling benefit.

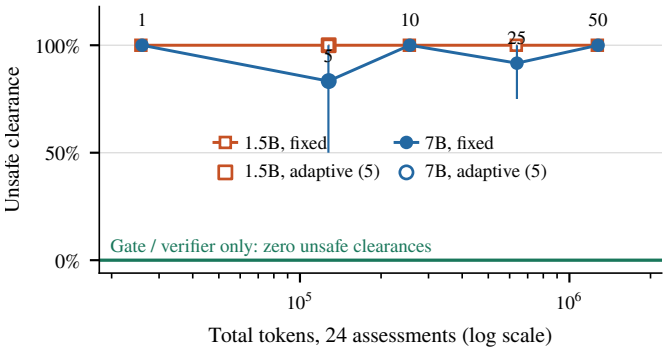

Fig. 2. E4: unsafe clearance (ungated, mean of 3 seeds; whiskers show the seed range) against total tokens. A 49× budget increase leaves unsafe clearance near 100%; the deterministic gate holds it at zero for every k.

TABLE IV
OWASP OUTCOMES ON 160 SELECTED CASES. PAIRED COUNTS ARE SEEDS 17/43; DENOMINATORS ARE FIXED ACROSS ROWS.

Method	Unsafe /100	Benign /60	Unresolved /160
Retain-all	0	0	0
Clear-without-signal	40	20	0
1 context	33/36	22/18	72/74
5 contexts	39/41	19/23	85/81
10 contexts (96 assessed)	31/28	16/19	111/113

At seed 17 the single context improves both clearance rates over clear-without-signal, but raises unresolved share and review workload (105 versus 100 cases). Seed 43 does not improve benign clearance. The data show trade-offs, not equivalence or statistically established superiority. On all 2,740 benchmark cases, clear-without-signal instead yields 2.8% unsafe and 53.3% benign clearance: the assessment sample deliberately includes all 40 unflagged real vulnerabilities. Sample rates must not be extrapolated to the full benchmark.

Answer to RQ1. On the authored controls, added contexts did not improve clearance utility; the gate prevented observed false clearances. OWASP provides no consistent joint improvement, and its ten-context result is confounded by assessment coverage.

B. RQ2: Does verifier feedback help the model?

We first calibrated JBMC on all 111 eligible SV-COMP tasks (unwind bound 20, 30 s per call): 64 properties were established under backend models, 25 counterexamples replayed on the JVM, and 22 outcomes were unresolved (12 counterexamples that the JVM did not reproduce, all involving String or library models; 8 different-property failures; one bounded result; one timeout). All 89 decisive outcomes agreed with the expected verdicts.

On the 32-task frozen subset (Fig. 3), the model without feedback returned a mean of 12.7 correct, 1 incorrect and 18.3 unresolved verdicts per seed. Feedback increased correct verdicts to 22.0, but also increased incorrect verdicts to 7 in each

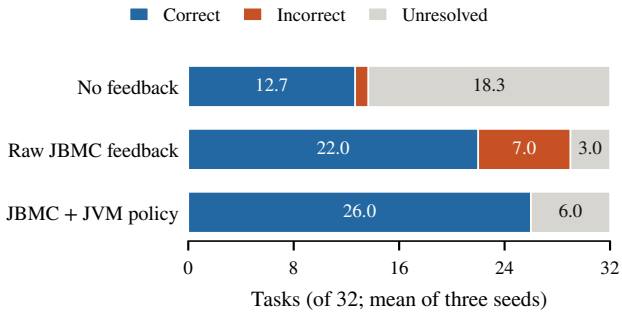

Fig. 3. E3 verdicts on 32 frozen tasks (means of three seeds). Raw feedback raises both correct and incorrect counts. The deterministic comparator additionally uses JVM validation.

seed. The deterministic JBMC-plus-JVM policy returned 26 correct and 6 unresolved verdicts. Its aggregate receipt records each task twice, once for each feedback group; we divide those duplicated counts by two rather than reporting 64 independent tasks.

The interfaces differ materially. Model feedback contains the raw JBMC outcome and failed-property records, not the JVM replay outcome or a full validated witness. The deterministic comparator additionally rejects non-replayed assertion failures and failures of other properties. Consequently, this experiment shows that raw feedback did not substitute for that validation policy; it does not establish that the model ignored an identical, fully validated evidence package. It evaluates verdict prediction, not agent-generated invariants or proof strategies.

C. RQ3: Can models recognise misleading evidence?

Fig. 4 separates the two error types. Without the gate the model accepted 0–3% of corrupted packages, all of them suppressing harnesses or missing obligations; the gate removed these. However, the model rejected 70–100% of *valid* counterexample packages. Inspected responses rejected a faithful counterexample because the original program still had a null dereference: the model judged the program instead of the evidence. We call this *applicability confusion*. JBMC feedback made it worse (87% in development, 100% on held-out templates), and the held-out templates replicated the development pattern. The scope validator alone accepted all 20 clean and rejected all 100 corrupted packages in both sets. Because the corruptions expose their mismatch in metadata or canonical harness text, this baseline solves the known construction; it is not a general semantic-preservation algorithm.

1) Worked applicability example: An actual template uses `create(x)` to return null when `x == 0`, and `entry(x)` dereferences the returned array over inputs 0–15. The clean package analyses that unchanged entry across the entire domain and reports a counterexample. Accepting the package means accepting evidence of a defect, not declaring the program safe. A restricted-domain corruption instead excludes the failing input and obtains solver success; that result is inapplicable to the original full-domain claim. The validator rejects it because the

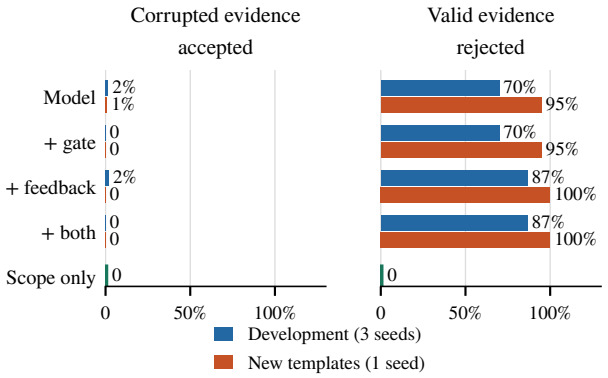

Fig. 4. E5 misleading-evidence challenge (100 corrupted and 20 clean packages per seed). The gate removes erroneous acceptance but cannot repair the model's rejection of valid evidence; the scope validator alone makes neither error.

TABLE V
E2 INDEPENDENT DISCOVERY ON DEFECTS4J CLI-1/2/3 (3 SEEDS). COUNTS ARE EXECUTED TEST SPECIFICATIONS, NOT INDEPENDENT BUGS.

Setting	Executed	Pass both	Fail both	Buggy/fixed differential
1 context, strict parser	0	0	0	0
5 contexts, strict parser	16	13	3	0
1 context, secondary parser	28	25	3	0
5 contexts, secondary parser	125	104	21	0
Contract-test baseline (no model)	180	171	9	0

recorded input domain differs, without asking a model to judge the explanation. Other corruptions use a suppressed call, an unrelated obligation, a changed revision or an unestablished callee contract.

This distinction explains why rejecting nearly everything is unhelpful. Without feedback, development clean acceptance was only 3–4/20 per seed; with feedback it was 2–3/20, and on the second template set it fell to 0/20. The gate preserves these rejections because it only vetoes unsupported acceptances. The observed explanatory pattern is therefore a useful diagnostic, although its prevalence in model reasoning was not independently coded.

D. RQ4: Can models discover defects unaided?

Table V reports E2. The model saw all 20 production files of each Cli target, with no warning or location, and proposed declarative tests. Under strict parsing, every single-context answer and 41 of 45 five-context answers violated the requested schema; a secondary parser, fixed before any rescue sampling and reported separately, recovered most of them. No generated test, and none of 180 deterministic public-API contract tests, failed on a buggy revision and passed on its fix. Cli-3 concerns typed numeric conversion, which our adapter does not expose, so it remains in the denominator as unsupported. Reproduction on held-out Lang bugs failed under JDK 11 (fixed revisions still fail 8 tests), while six Csv, Codec and Compress bugs reproduced and await assessment.

V. DISCUSSION

What the gate demonstrates. Across the E1 and E4 configurations, postprocessing removed 161 unsafe clearances; across both E5 sets it removed 12 erroneous acceptances. These are repeated decisions, not distinct defects. It removed no correct clearance or package acceptance in these constructions, but inherited model abstentions and clean-package rejections. The stronger tools-only baselines already had the necessary evidence, so the gate's success is a consistency check rather than an independent gain in verification capability. This supports the evidence-controlled disposition used by Evident [4] within the boundaries tested here.

What scaling demonstrates. Homogeneous models with repeated evidence can share errors, consistent with prior diversity-based analyses [9]. We did not estimate error correlation or isolate role diversity from sampling. Larger teams also include roles poorly matched to null dereferences and receive different per-context caps. Thus the experiment challenges this fixed catalogue and aggregation rule, not the usefulness of specialised teams with complementary tools, iterative communication or stronger models. A useful next comparison would give a single model the same total inference budget and compare identical evaluated cases.

Applicability as a separate outcome. Evidence can be applicable precisely because it demonstrates failure. Evaluations should therefore measure acceptance of valid counterexamples as well as rejection of invalid assurance claims. E5 exposes that distinction, while its known constructions make deterministic scope checks unusually strong. Tests using independently authored harnesses, applicable proofs of benign programs and semantically equivalent alternative harnesses are needed to measure general applicability reasoning.

VI. THREATS TO VALIDITY

Construct validity. OWASP is scored at case/CWE level, not by independently adjudicated warning location, and includes unflagged cases; it is a case-assessment experiment rather than pure warning filtering. E5 clean packages are all counterexamples and corrupted packages all solver successes, confounding applicability with outcome type. The canonical-text validator may reject an equivalent unfamiliar harness. E2's adapter cannot exercise Cli-3's target API, and its test counts do not measure semantic diversity.

Internal validity. Development controls were revised after zero-warning attempts. E3 compares raw feedback with a baseline that also uses JVM validation. Input/output caps vary with team size, actual token use differs, and OWASP's ten-context arm omits 64 cases. E2's secondary parser was chosen after six completed outputs, before rescue sampling; it is a post hoc diagnostic, not the original primary analysis. Frozen request hashes prevent later input changes but are not preregistration. An independent implementation audit remains outstanding.

External validity. Only two small models from one family were evaluated; the second model appears only in the eight-control scaling study. OWASP is one synthetic application,

E2 covers one project, and E3 admits 111 of 1,033 manifests. Developer-authored E5 templates are not independently designed challenges. Public benchmark contamination remains possible; source identities were not comprehensively masked. The prepared family-disjoint Juliet split does not establish generalization without model evaluation on it.

Conclusion validity. Seeds, templates and packages are dependent, and no effect-size threshold or power analysis was fixed for this exploratory report. We make no significance, equivalence or universal soundness claim. JVM replay independently supports failures; successful JBMC outcomes remain conditional on its library models and parser, with no independently checked proof certificate. Failed attempts and unassessed tasks are distinguished from observed negative results.

VII. Conclusion

In the tested Java settings, additional single-turn specialist contexts did not produce a consistent assurance benefit over the available deterministic controls. Raw verifier feedback increased correct model verdicts but also increased incorrect verdicts. Construction-specific scope checks prevented observed unsupported acceptances, while model rejection of applicable counterexamples limited utility. These findings favour retaining deterministic evidence admission when the required checks are available. They motivate broader, budget-matched evaluation rather than a general claim against multi-agent software assurance.

Data Availability

The private research repository archives executable adapters, model/configuration pins, aggregate receipts, selection manifests and SHA-256 provenance. Figures and tables in this paper derive from those receipts. Raw model responses, benchmark sources and solver traces are retained separately; this manuscript does not claim a public artifact release. A review package requires access arrangements and upstream licence checks. The pending 2,032-case Juliet comparison, six reproduced Csv/Codec/Compress targets and independently authored E5 challenge are not reported as completed experiments.

Acknowledgment

Experiments used the University of Manchester CSF3 cluster and Google Colab.

References

[1] M. R. Ameen, M. T. U. Alam, and A. Islam, "QASecClaw: A multi-agent LLM approach for false positive reduction in static application security testing," 2026, arXiv preprint arXiv:2605.01885.

[2] Z. Li, S. Dutta, and M. Naik, "IRIS: LLM-assisted static analysis for detecting security vulnerabilities," in *Proceedings of the International Conference on Learning Representations (ICLR)*, 2025, arXiv:2405.17238.

[3] W. Klieber, D. Svoboda, L. Flynn, and R. Martins, "Using LLMs to adjudicate static-analysis alerts with error reduction techniques," arXiv preprint arXiv:2607.09979, 2026.

[4] H. Li, T. Zhou, M. Sridharan, H. Zhang, and Z. Qian, "The hitchhiker's guide to program analysis, part III: Mostly harmless LLMs," 2026, arXiv preprint arXiv:2606.15122v2.

[5] A. Wu, N. Roberts, T.-H. Huang, H. Lin, G. Friedman, S. Cho, G. Orlanski, and F. Sala, "MAGS: Multi-agent auto-formalization guarantees safety for agentic outputs," 2026, arXiv preprint arXiv:2609.19391.

[6] T. Lin, Z. Wang, H. Li, J. Yin, and M. Chen, "VERDICT: Multi-agent parallel modular verification," 2026, arXiv:2610.29147. Accepted at ICSE 2027.

[7] J. Li, Q. Zhang, Y. Yu, Q. Fu, and D. Ye, "More agents is all you need," *Transactions on Machine Learning Research*, 2024.

[8] Y. Kim, K. Gu, C. Park, C. Park, S. Schmidgall, A. A. Heydari, Y. Yan, Z. Zhang, Y. Zhuang, Y. Liu, M. Malhotra, P. P. Liang, H. W. Park, Y. Yang, X. Xu, Y. Du, S. Patel, T. Althoff, D. McDuff, and X. Liu, "Towards a science of scaling agent systems," 2025, arXiv preprint arXiv:2512.08296.

[9] Y. Yang, C. Qu, M. Wen, L. Shi, Y. Wen, W. Zhang, A. Wierman, and S. Gu, "Understanding agent scaling in LLM-based multi-agent systems via diversity," 2026, arXiv preprint arXiv:2602.03794.

[10] S. Xia, Q. Li, T. Ehsan, and J. Ortiz, "TraceFix: Repairing agent coordination protocols with TLA+ counterexamples," 2026, arXiv preprint arXiv:2605.07935.

[11] H. J. Kang, K. L. Aw, and D. Lo, "Detecting false alarms from automatic static analysis tools: How far are we?" in *Proceedings of the 44th International Conference on Software Engineering (ICSE)*, 2022, pp. 698–709.

[12] Y. Ding, Y. Fu, O. Ibrahim, C. Sitawarin, X. Chen, B. Alomair, D. Wagner, B. Ray, and Y. Chen, "Vulnerability detection with code language models: How far are we?" in *Proceedings of the IEEE/ACM 47th International Conference on Software Engineering (ICSE)*, 2025, pp. 1729–1741.

[13] H. Wu, C. Barrett, and N. Narodytska, "Lemur: Integrating large language models in automated program verification," in *The Twelfth International Conference on Learning Representations (ICLR 2024)*, 2024, arXiv:2310.04870. [Online]. Available: https://openreview.net/forum?id=Q3YaCghZNt

[14] L. Ma, S. Liu, Y. Li, X. Xie, and L. Bu, "SpecGen: Automated generation of formal program specifications via large language models," in *Proceedings of the IEEE/ACM 47th International Conference on Software Engineering (ICSE 2025)*. IEEE, 2025, pp. 16–28, arXiv:2401.08807.

[15] M. A. A. Pirzada, J. Parsert, W. Wang, K. Korovin, and L. C. Cordeiro, "Neuro-symbolic software verification: Hyper-charging local language models with symbolic reasoning at scale," 2026, arXiv preprint arXiv:2606.16886.

[16] L. Cordeiro, P. Kesseli, D. Kroening, P. Schrammel, and M. Trtik, "JBMC: A bounded model checking tool for verifying Java bytecode," in *Computer Aided Verification (CAV 2018)*, ser. Lecture Notes in Computer Science, H. Chockler and G. Weissenbacher, Eds. Springer, 2018, pp. 183–190.

[17] National Institute of Standards and Technology, "Juliet Java 1.3, software assurance reference dataset, test suite 111," https://samate.nist.gov/SARD/test-suites/111, 2017, accessed: 2026-10-26.

[18] OWASP Foundation, "OWASP benchmark project, version 1.2," https://owasp.org/www-project-benchmark/, java test suite: https://github.com/OWASP-Benchmark/BenchmarkJava. Accessed: 2026-10-26.

[19] SpotBugs Team, "SpotBugs: Find bugs in Java programs," https://spotbugs.github.io/, accessed: 2026-10-26.

[20] Find Security Bugs Project, "Find security bugs: The SpotBugs plugin for security audits of Java web applications," https://find-sec-bugs.github.io/, version 1.14.0. Accessed: 2026-10-26.

[21] R. Just, D. Jalali, and M. D. Ernst, "Defects4J: A database of existing faults to enable controlled testing studies for Java programs," in *Proceedings of the 2014 International Symposium on Software Testing and Analysis (ISSTA)*, 2014, pp. 437–440.

[22] D. Beyer and J. Strejček, "Improvements in software verification and witness validation: SV-COMP 2025," in *Tools and Algorithms for the Construction and Analysis of Systems (TACAS 2025)*, ser. Lecture Notes in Computer Science, A. Gurfinkel and M. Heule, Eds., vol. 15698. Springer, 2025, pp. 151–186.

[23] B. Hui, J. Yang, Z. Cui, J. Yang, D. Liu, L. Zhang, T. Liu, J. Zhang, B. Yu, K. Lu, K. Dang, Y. Fan, Y. Zhang, A. Yang, R. Men, F. Huang, B. Zheng, Y. Miao, S. Quan, Y. Feng, X. Ren, X. Ren, J. Zhou, and J. Lin, "Qwen2.5-Coder technical report," arXiv preprint arXiv:2409.12186, 2024.